

SOC/L1 - 2. SOC Team Internals

SOC L1 Alert Triage

Alert Management Platforms

Solution	Examples	Description
SIEMSystem	Splunk ES, Elastic	SIEM have solid alert management capabilities and are a perfect choice for most SOC teams
EDR orNDR	MS Defender,CrowdStrike	While EDR and NDR provide their own alert dashboards, it is preferred to use SIEM or SOAR
SOARSystem	Splunk SOAR,Cortex SOAR	Bigger SOC teams can use SOAR to aggregate and centralise alerts from multiple solutions
ITSMSystem	Jira,TheHive	Some teams may have a custom ticket management (ITSM) setup using a dedicated solution(The GIF above is taken from Trello, a simple tool that can be adapted to ITSM needs)

- **SOC L1 analysts:** Review the alerts, distinguish bad from good, and notify L2 analysts in case of a real threat
- **SOC L2 analysts:** Receive the alerts escalated by L1 analysts and perform deeper analysis and remediation
- **SOC engineers:** Ensure the alerts contain enough information required for efficient alert triage
- **SOC manager:** Track speed and quality of alert triage to ensure that real attacks won't be missed

Alert Properties

Time	Name	Severity	Status	Verdict	Assignee	Actions
1 Mar 21st 2025 at 11:53	2 Bruteforce Attack from External	3 Medium	4 Closed	5 True Positive	6 J.Adams (L2)	
Mar 21st 2025 at 13:58	Double-Extension File Creation	High	Awaiting action	None	None	
Description: 7 This rule detects a creation of a double-extension file like *.pdf.exe or *.gif.lnk, often used by hackers in phishing attacks to trick users into opening the malicious executable. Host: LPT-HR-009 Process Name: chrome.exe Process User: S.Conway Target File: 8 C:\Users\S.Conway\Downloads\cats2025.mp4.exe File MD5: https://freecatvideoshd.monster/cats2025.mp4.exe File MD5: 14d8486f3f63875ef93cfd240c5dc10b						

Nº	Property	Description	Examples
1	Alert Time	Shows alert creation time. Alert usually triggers a few minutes after the actual event	• Alert Time: March 21, 15:35 • Event Time: March 21, 15:32
2	Alert Name	Provides a summary of what happened, based on the detection rule's name	• Unusual Login Location • Email Marked as Phishing • Windows RDP Bruteforce • Potential Data Exfiltration
3	Alert Severity	Defines the urgency of the alert, initially set by detection engineers, but can be altered by analysts if needed	• (Low) Low / Informational • (Medium) Medium / Moderate • (High) High / Severe • (Critical) Critical / Urgent
4	Alert Status	Informs if somebody is working on the alert or if the triage is done	• (NEW) New / Unassigned • (In Progress) In Progress / Pending • (Closed) Closed / Resolved • And often other custom statuses
5	Alert Verdict	Also called alert classification, explains if the alert is a real threat or noise	• (True Positive) True Positive / Real Threat • (False Positive) False Positive / No Threat

Nº	Property	Description	Examples
			• And often other custom verdicts
6	Alert Assignee	Shows the analyst that was assigned or assigned themselves to review the alert	• Assignee can sometimes be called alert owner • Assignee takes responsibility for their alerts
7	Alert Description	Explains what the alert is about, usually in three sections on the right	• The logic of the alert generating rule • Why this activity can indicate an attack • Optionally, how to triage this alert
8	Alert Fields	Provides SOC analysts' comments and values on which the alert was triggered	• Affected Hostname • Entered Commandline • And many more, depending on the alert

Alert Prioritisation: Every SOC team decides on its own prioritisation rules and usually automates them by setting the appropriate alert sorting logic in SIEM or EDR. Below, you may see the generic, simplest, and most commonly used approach:

1. **Filter the alerts:** Make sure you don't take the alert that other analysts have already reviewed, or that is already being investigated by one of your teammates. You should only take new, yet unseen and unresolved alerts.
2. **Sort by severity:** Start with critical alerts, then high, medium, and finally low. This is because detection engineers design rules so that critical alerts are much more likely to be real, major threats and cause much more impact than medium or low ones.
3. **Sort by time:** Start with the oldest alerts and end with the newest ones. The idea is that if both alerts are about two breaches, the hacker from the older breach is likely already dumping your data, while the "newcomer" has just started the discovery.

Alert Triage



Initial Actions: The initial steps are designed to ensure that you take ownership of the assigned alert and avoid interfering with alerts being handled by other analysts, and confirm that you are fully prepared to proceed with the detailed investigation. You achieve it by first assigning the alert to yourself, moving it to **In Progress**, and then familiarising yourself with the alert details like its name, description, and key indicators.

Investigation: This is the most complex step, requiring you to apply your technical knowledge and experience to understand the activity and properly analyse its legitimacy in SIEM or EDR logs. To support L1 analysts with this step, some teams develop **Workbooks** (also known as playbooks or runbooks) - instructions on how to investigate the specific category of alerts. If workbooks are not available, below are some key recommendations:

1. Understand who is under threat, like the affected user, hostname, cloud, network, or website
2. Note the action described in the alert, like whether it was a suspicious login, malware, or phishing
3. Review surrounding events, looking for suspicious actions shortly after or before the alert
4. Use threat intelligence platforms or other available resources to verify your thoughts

Final Actions: Your decisions here determine whether you found or missed the potential cyberattack. Some actions like **Escalation** or **Commenting** will be explained in the following rooms, so don't worry if they sound complex right now. First, decide if the alert you investigated is malicious (True Positive) or not (False Positive). Then, prepare your detailed comment explaining your analysis steps and verdict reasoning, return to the dashboard and move it to the **Closed** status.

SOC L1 Alert Reporting

Alert Funnel: An alert funnel describes how security teams process huge numbers of security signals

Alert Reporting: Before closing or passing the alert to L2, you might have to report it. Depending on team standards and alert severity, instead of a short alert comment, you can be required to document your investigation in detail, ensuring all relevant evidence is included. This is especially important for True Positives, which require escalation.

Alert Escalation: If the True Positive alert requires additional actions or deeper investigation, escalate it to the L2 analyst for further review following the agreed procedures. That's where your alert report comes in handy since L2 will use it to get the initial context and spend less on the analysis from scratch.

Communication: You may also need to communicate with other departments during or after the analysis. For example, ask the IT team if they confirm granting administrative privileges to some users or contact HR to get more information about the newly hired employee.

What is the process of passing suspicious alerts to an L2 analyst for review?
Alert Escalation

What is the process of formally describing alert details and findings? Alert Reporting

Reporting Guide

Alert Report Purpose	Explanation
Provide context for escalation	• A well-written report saves lots of time for L2 analysts • Also, it helps them quickly understand what happened

Save findings for the records	• Raw SIEM logs are stored for 3-12 months, but alerts are kept indefinitely • As a result, it's better to keep all the context inside the alert, just in case
Improve investigation skills	• If you can't explain it simply, you don't understand it well enough • Report writing is a great way to boost L1 skills by summarising alerts

Report Format

Imagine yourself as an L2 analyst, a DFIR team member, or an IT professional who needs to understand the alert. What would you want to see in the report? We recommend you follow the **Five Ws** approach and include at least these items in the report:

- **Who:** Which user logs in, runs the command, or downloads the file
- **What:** What exact action or event sequence was performed
- **When:** When exactly did the suspicious activity start and ended
- **Where:** Which device, IP, or website was involved in the alert
- **Why:** The most important W, the reasoning for your final verdict

Escalation Guide: After you have made a verdict and written your alert report, you must choose whether to escalate the alert to L2. Again, the answer may differ from team to team, but the following recommendations would generally fit most SOC teams. You should escalate the alerts if:

1. The alert is an indicator of a major cyberattack requiring deeper investigation or DFIR
2. Remediation actions like malware removal, host isolation, or password reset are required
3. Communication with customers, partners, management, or law enforcement agencies is required
4. You just do not fully understand the alert and need some help from more senior analysts

Escalation Steps: To escalate the alert, in most cases, all you have to do is to **reassign the alert to the L2 on shift** and ping them in corporate chat or in person. In some teams though, you may be required to create a formal written escalation request with dozens of required fields.

No matter what the agreements are, L2 will eventually receive the ticket from you, read your report, and contact you in case of any questions. Once everything is clear, the L2 analyst will typically research the alert details further, validate if the alert is indeed a True Positive, communicate with other departments if needed, and, for major incidents, start a formal Incident Response process.

Requesting L2 Support: It is generally fine for L1 to request senior support if something is unclear. Especially in your first months, it's always better to discuss the alert and clarify SOC procedures than to blindly close the alert you don't understand yourself. The procedures for requesting support may differ, but the flow generally looks like this:

SOC Dashboard Escalation

1. Move the alert to **In Progress** status and do the analysis
2. Write an alert report and set your **verdict**, such as True Positive
3. If escalation is required, assign the alert **to your L2** on shift
4. L2 will receive a notification and start from your alert report

SOC Communication: The escalation and reporting topics should sound straightforward and logical to you. But, as always, it's easier said than done, and you should be prepared for unexpected scenarios and know what to do in critical cases. In the best scenario, the SOC team has its own **Crisis**

Communication procedures - the guides and processes to help you and your teammates resolve the issues. If not, you are advised to read the cases below and be prepared to handle them effectively.

Communication Cases

- **You need to escalate an urgent, critical alert, but L2 is unavailable and does not respond for 30 minutes.**

Ensure you know where to find emergency contacts. First, try to call L2, then L3, and finally your manager.

- **The alert about Slack/Teams account compromise requires you to validate the login with the affected user.**

Do not contact the user through the breached chat - use alternative contact methods like a phone call.

- **You receive an overwhelming number of alerts during a short period of time, some of which are critical.**

Prioritise the alerts according to the workflow, but inform your L2 on shift about the situation.

- **After a few days, you realise that you misclassified the alert and likely missed a malicious action.**

Immediately reach out to your L2 explaining your concerns. Threat actors can be silent for weeks before impact.

- **You can not complete the alert triage since the SIEM logs are not parsed correctly or are not searchable.**

Do not skip the alert - investigate what you can and report the issue to your L2 on shift or SOC engineer.

Should you first try to contact your manager in case of a critical threat (Yea/Nay)? Nay

Should you immediately contact your L2 if you think you missed the attack (Yea/Nay)? Yea

SOC Workbooks and Lookups

Identity Inventory

Identity inventory is a catalogue of corporate employees (user accounts), services (machine accounts), and their details like privileges, contacts, and roles within the company. For the scenario above, identity inventory would help you get context

about G.Baker and R.Lund, and make it simpler to decide if the activity was expected or not.

Sources of Identities

Solution	Examples	Description
Active Directory	On-prem AD, Entra ID	AD itself is an identity database, and it is commonly used by SOC
SSO Providers	Okta, Google Workspace	Cloud alternative for AD, an easy way to manage and search the users
HR Systems	BambooHR, SAP, HiBob	Limited to employees only, but usually provides full employee data
Custom Solution	CSV or Excel Sheets	It is common for IT or security teams to maintain their own solutions

Asset Inventory: Asset inventory, also called asset lookup, is a list of all computing resources within an organisation's IT environment. Note that while "asset" is a vague term and can also refer to software, hardware, or employees, this room emphasises servers and workstations only. For the scenario above, asset inventory would help you get context about the HQ-FINFS-02 server.

Sources of Assets

Solution	Examples	Description
Active Directory	On-prem AD, Entra ID	AD is not only an identity but also a solid asset inventory database
SIEM or EDR	Elastic, CrowdStrike	Some SIEM or EDR agents collect information about the monitored hosts
MDM Solution	MS Intune, Jamf MDM	A dedicated class of solutions created to list and manage assets
Custom Solution	CSV or Excel Sheets	Same as with the identity inventory, custom solutions are common

Network Diagrams: Continuing identity and asset inventory topics, you might also need to look at the alert from a network point of view, especially in bigger companies. Consider the scenario where you are investigating a chain of related alerts based on firewall logs and want to give some meaning to the IPs you see:

1. **08:00:** An IP **103.61.240.174** is repeatedly connecting to a corporate firewall via port **TCP/10443**
2. **08:23:** Firewall logs show that the IP 103.61.240.174 was translated to an internal **10.10.0.53** IP
3. **08:25:** The IP 10.10.0.53 is scanning the **172.16.15.0/24** network range but does not find open ports
4. **08:32:** The same IP is now scanning the **172.16.23.0/24** network range, and the attack seems to be ongoing

Workbooks Theory: With asset inventory and network diagrams, you can get enough context about the user, host, or IP address. Next, your task is to make a verdict on whether the activity you see is safe or not. For some alerts, the analysis is simple, but some may require dozens of essential steps that must be followed to avoid missing vital details and confusing attack evidence. So, how can you ensure all the analysis steps are always followed?

SOC Workbooks

SOC workbook, also called playbook, runbook, or workflow, is a structured document that defines the steps required to investigate and remediate specific threats efficiently and consistently. Since L1 analysts are considered junior specialists and are not expected to triage every possible attack scenario perfectly, senior analysts often prepare workbooks to support their less experienced teammates. L1 analysts are recommended and sometimes even required to triage the alerts precisely according to workbooks to avoid mistakes and streamline the analysis.

Workbook Example: Unusual Login Location Workbook: The diagram above is a typical example of an investigation workbook aimed to help L1 analysts triage alerts about atypical email, web, or corporate VPN login. Most workbook diagrams are supplemented with a detailed textual guide and links to the mentioned resources. Also, note how the workbook is divided into three logical groups. By following the steps in the correct order, you can guarantee high-quality alert triage and eliminate cases where the verdict is made without enough evidence:

1. **Enrichment:** Use Threat Intelligence and identity inventory to get information about the affected user
2. **Investigation:** Using the gathered data and SIEM logs, make your verdict if the login is expected
3. **Escalation:** Escalate the alert to L2 or communicate the login with the user if necessary

Which SOC role would use workbooks the most (e.g. SOC Manager)? SOC L1 Analyst

What is the process of gathering user, host, or IP context using TI and lookups? Enrichment

Looking at the workbook example, what platform is used as an identity inventory source? BambooHR

SOC Metrics and Objectives

To begin with, let's recall the main goal of a SOC - to protect the confidentiality, integrity, and availability of the organisation's digital assets. The SOC team performs its purpose by developing, receiving, and triaging alerts. The L1 analysts' role in this process is to reliably report True Positives to the higher level, to L2. This leads us to the first four metrics:

Metric	Formula	Measures
Alerts Count	$AC = \text{Total Count of Alerts Received}$	Overall load of SOC analysts
False Positive Rate	$FPR = \text{False Positives} / \text{Total Alerts}$	Level of noise in the alerts
Alert Escalation Rate	$AER = \text{Escalated Alerts} / \text{Total Alerts}$	Experience of L1 analysts
Threat Detection Rate	$TDR = \text{Detected Threats} / \text{Total Threats}$	Reliability of the SOC team

Alerts Count: Imagine starting your shift and seeing 80 unresolved alerts in the queue. That's definitely overwhelming and prone to missing real threats hiding behind the noise spam. On the other hand, consider a whole week without any

alerts. Sounds better at first glance, but also concerning since a too low count of alerts may indicate an issue in the SIEM or lack of visibility, leading to undetected breaches. The ideal metric value depends on company size but in general, **5 to 30 alerts per day per L1 analyst is a good metric.**



False Positive Rate: If 75 out of 80 alerts (94%) were confirmed to be False Positives like system noise or typical IT activity - that's a bad signal for your team. With more noise, analysts tend to become less vigilant and more likely to miss the threat and treat all alerts just like "yet another spam". A False Positive rate of **0% is an unachievable ideal, but 80% or higher is a serious problem**, usually fixed by a tool and detection rules tuning, often called "False Positive Remediation".

Alert Escalation Rate: L2 analysts rely on L1 to filter out the noise and escalate only the actionable, threatening alerts. At the same time, as L1, you don't want to be overconfident and triage alerts you do not fully understand without a senior support. The alert escalation rate comes in handy to evaluate how experienced and independent the L1 analysts are and how often they decide to escalate the alert. It is usually **aimed to be below 50%, or even better below 20%.**



Threat Detection Rate: Imagine that out of six attacks for 2025, your SOC team detected and prevented four attacks, missed the fifth because of the broken detection rule, and the sixth because one of the L1 analysts misclassified the breach as False Positive. The resulting metric is $TDR = 4 / 6 = 67\%$, and this is a very bad result. The threat detection rate **should always be at 100%** since every missed threat can have devastating consequences, such as ransomware infection and data exfiltration.

| Is zero alerts for one month a good sign for your SOC team? (Yea/Nay) Nay

| What is the False Positive Rate if only 10 out of 50 alerts appear to be real threats? 80%

Triage Metrics: Next, remember that an alert by itself will not stop the breach, and it is important to timely receive the alert, triage it, and respond to the attack before

the attackers achieve their goals. The requirements to ensure a quick detection and remediation of the threat are commonly grouped into a **Service Level Agreement (SLA)** - a document signed between the internal SOC team and its company management, or by the managed SOC provider (MSSP) and its customers. The agreement usually requires quick threat detection (measured by **MTTD**), timely alert acknowledgement by L1 analysts (measured by **MTTA**), and finally, prompt response to the threat, like isolating the device or securing the breached account (measured by **MTTR**):

Reference Table: Note that different teams might have different definitions or formulas for the SOC metrics, depending on what they want to measure. For this and the following tasks, please use the illustration above and the reference table below to answer the questions.

Metric	Common SLA	Description
SOC Team Availability	24/7	Working schedule of the SOC team, often Monday-Friday (8/5) or 24/7 mode
Mean Time to Detect (MTTD)	5 minutes	Average time between the attack and its detection by SOC tools
Mean Time to Acknowledge (MTTA)	10 minutes	Average time for L1 analysts to start triage of the new alert
Mean Time to Respond (MTTR)	60 minutes	Average time taken by SOC to actually stop the breach from spreading

Imagine a scenario where the SOC team receives a critical alert on Saturday. If the team works 8/5, on which day of the week will they acknowledge the alert?
Monday

Imagine a scenario where an employee was lured into running data stealer malware.

1. The SOC team received the "Connection to Redline Stealer C2" alert after 12 minutes.
2. One of the L1 analysts on shift moved the alert to In Progress 10 minutes later.
3. After 6 minutes, the alert was escalated to L2, who spent 35 minutes cleaning the malware.

Provide the MTTD, MTTA, and MTTR via comma as your answer (e.g. 10,20,30).

12,10,51

Improving Metrics: Now that you know a lot about different metrics, why would it matter to you as an L1 analyst? First, you should understand that metrics were built to make the SOC more efficient and, therefore, to make the attacks far less successful. Second, the metrics are often used to evaluate your performance, and good results lead to career growth and a raise to more senior positions like L2 analyst. So, how can you improve the metrics?

Reference Table

Issue	Recommendations
False Positive Rate over 80%	Your team receives too much noise in the alerts. Try to: 1. Exclude trusted activities like system updates from your EDR or SIEM detection rules 2. Consider automating alert triage for most common alerts using SOAR or custom scripts
Mean Time to Detect over 30 min	Your team detects a threat with a high delay. Try to: 1. Contact SOC engineers to make the detection rules run faster or with a higher rate 2. Check if SIEM logs are collected in real-time, without a 10-minute delay
Mean Time to Acknowledge over 30 min	L1 analysts start alert triage with a high delay. Try to: 1. Ensure the analysts are notified in real-time when a new alert appears 2. Try to evenly distribute alerts in the queue between the analysts on shift
Mean Time to Respond over 4 hours	SOC team can't stop the breach in time. Try to: 1. As L1, make everything possible to quickly escalate the threats to L2 2. Ensure your team has documented what to do during different attack scenarios

What is the highest acceptable False Positive Rate for SOC teams? 80%

Should all SOC roles work together to keep metrics improving? (Yea/Nay) Yea

